



Ethical Hacking

Dosen: Hendi Hermawan, S.T., M.T.I

ANALISIS ALERT KEAMANAN PADA OWASP JUICE SHOP MENGUNAKAN ZED ATTACK PROXY (ZAP)

Present By :

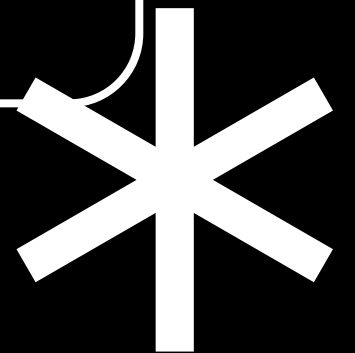
- Annaufal Afif Seno 2023071054
- Khairun Nisa Al Hakim 2024071001
- Qurratu Farrasah Siregar 2024071017

TARGET & RUANG LINGKUP

KOmponen	Detail
Tool	OWASP ZAP (Zed Attack Proxy)
Aplikasi Target	OWASP Juice Shop
Alamat Target	http://127.0.0.1:3000
Proxy	127.0.0.1 port 8090
Browser	Mozilla Firefox
Jenis Pengujian	Passive scan, spidering, analisis header, validasi manual

Batasan Aktivitas

- Tidak melakukan brute force atau DoS
- Hanya menguji aplikasi latihan lokal
- Tidak menyentuh sistem publik kampus
- Mencatat request dan respons HTTP



ARSITEKTUR PRAKTIKUM

Pengujian dilakukan pada aplikasi OWASP Juice Shop menggunakan OWASP ZAP sebagai proxy dan alat analisis keamanan. Browser Firefox dikonfigurasi agar seluruh traffic HTTP melewati ZAP sehingga request dan response dapat dipantau secara langsung.

Arsitektur pengujian terdiri dari:

- User menggunakan Mozilla Firefox
- Traffic HTTP diteruskan ke OWASP ZAP
- ZAP melakukan passive scan, spidering, dan analisis header
- Request kemudian diteruskan ke target aplikasi OWASP Juice Shop yang berjalan pada Docker di `http://127.0.0.1:3000`

Metode pengujian yang digunakan meliputi:

- Passive scanning
- Spidering ringan
- Analisis HTTP header
- Validasi manual terhadap temuan keamanan



KONFIGURASI PROXY

Konfigurasi pada OWASP ZAP

Buka OWASP ZAP > Buka menu Tools > Option > Local Proxies > Pastikan Address diisi 127.0.0.1 dan Port 8090 > Klik OK

Konfigurasi pada Firefox

Masuk ke Settings > General > Network Settings > Settings > Pilih Manual Proxy configuration > Isi HTTP Proxy 127.0.0.1 dan Port 8090 > Centang Also use this proxy for HTTPS (Opsional untuk traffic HTTPS) > Klik OK

Instalasi Sertifikat ZAP

Tools > Option > Generate Dynamic SSL Certificate di ZAP > Simpan > Impor ke Firefox via View Certificate > Import > Centang opsi Trust this CA to identify websites

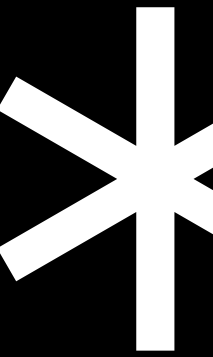
Verifikasi Koneksi Proxy

Akses <http://127.0.0.1:3000> di Firefox > Request harus muncul di tab History atau Sites di ZAP > Berhasil jika request tertangkap

RINGKASAN ENDPOINT

Kategori	Method	Endpoint	Parameter	Status	Keterangan
Auth	POST	/rest/user/login	email, password	200/401	JWT Issued / Kredensial salah
Auth	POST	/api/Users	email, securityQuestion	200	Registrasi akun baru berhasil
Produk	GET	/rest/products/search	q=apple'	500	Indikasi SQL Injection (Petik tunggal)
Profil	PUT	/api/Users/.id	username	200	Update data user profil
Belanja	POST	/api/BasketItems	Producttd, quantity	200	Tambah produk ke keranjang
Belanja	DELETE	/api/BasketItems/;id	id item	200	Hapus item dari keranjang
Admin (Gagal)	GET	/#/administration	---	401	Akses tanpa login admin ditolak

TIGA TEMUAN UTAMA



1. Absence of Anti-CSRF Tokens

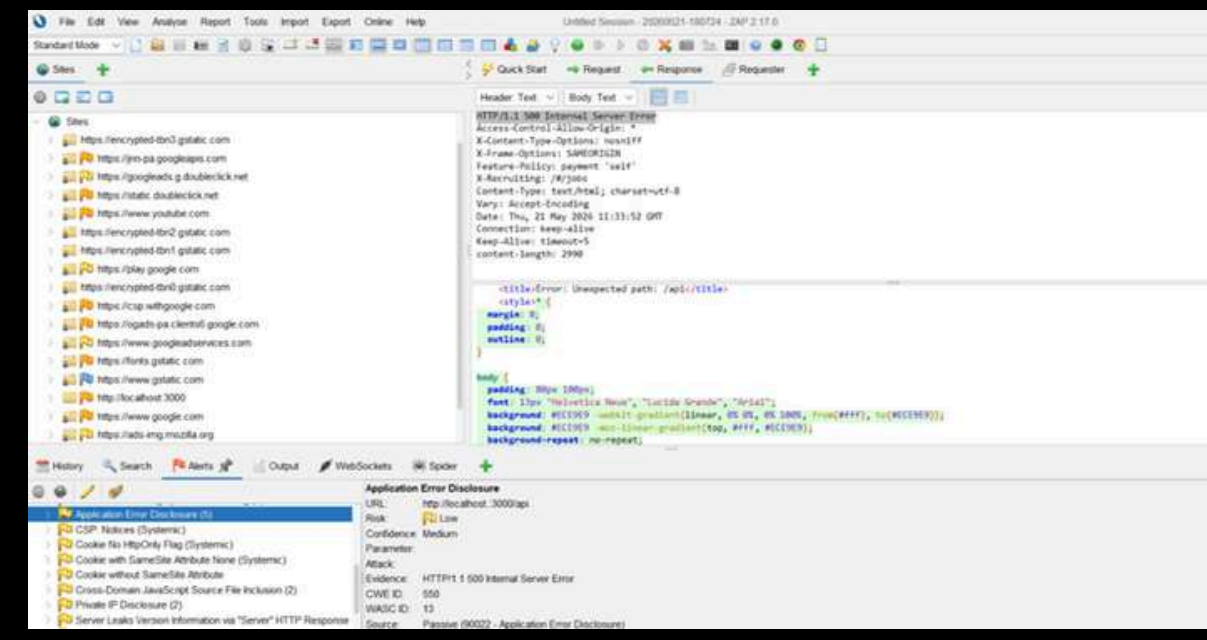
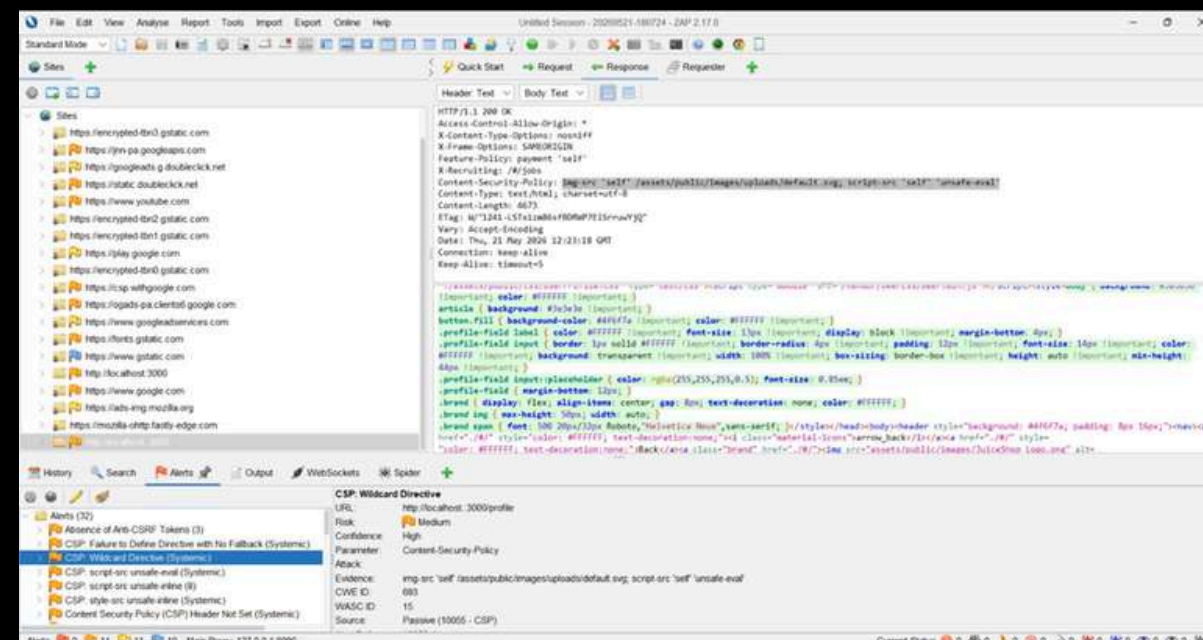
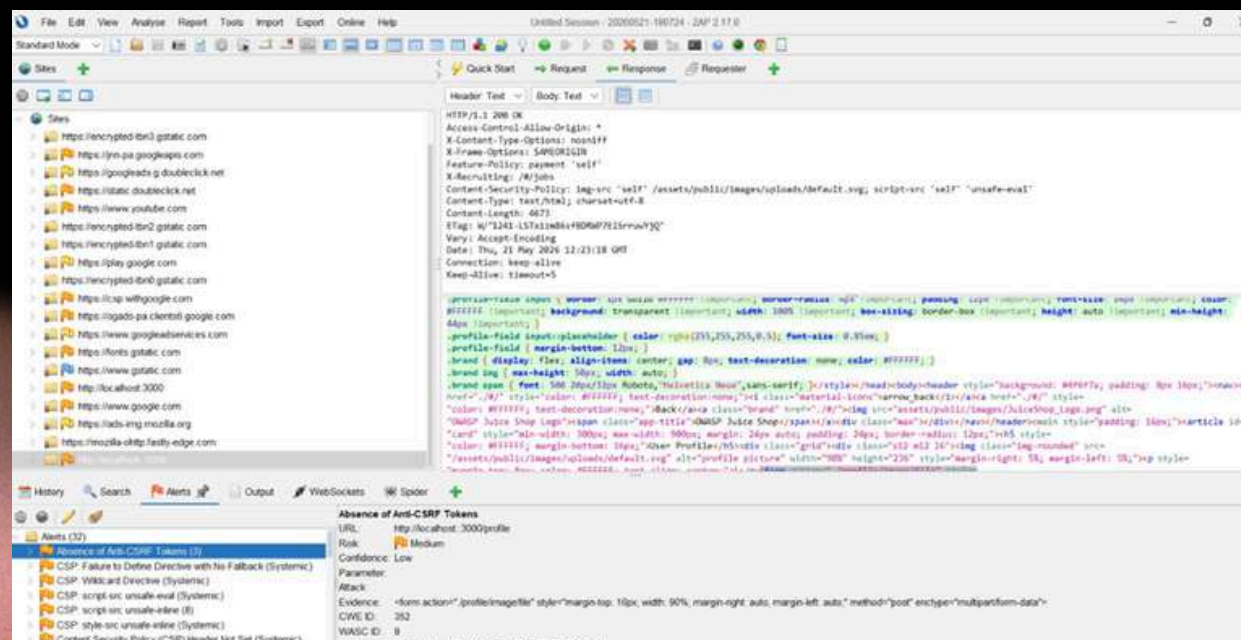
Form POST pada endpoint /profile tidak memiliki token CSRF. Kondisi ini dapat dimanfaatkan penyerang untuk mengirim request atas nama pengguna tanpa izin.

2. CSP: Wildcard Directive

Header Content-Security-Policy masih menggunakan unsafe-eval sehingga perlindungan terhadap eksekusi script berbahaya menjadi lemah.

3. Application Error Disclosure

Server menampilkan detail error internal seperti Unexpected path: /api/ yang dapat membantu penyerang memahami struktur aplikasi.



VALIDASI MANUAL

Validasi manual dilakukan terhadap cookie sesi JWT pada endpoint /profile. Pemeriksaan dilakukan melalui header Set-Cookie yang tertangkap pada OWASP ZAP setelah pengguna login dan mengakses halaman profile.

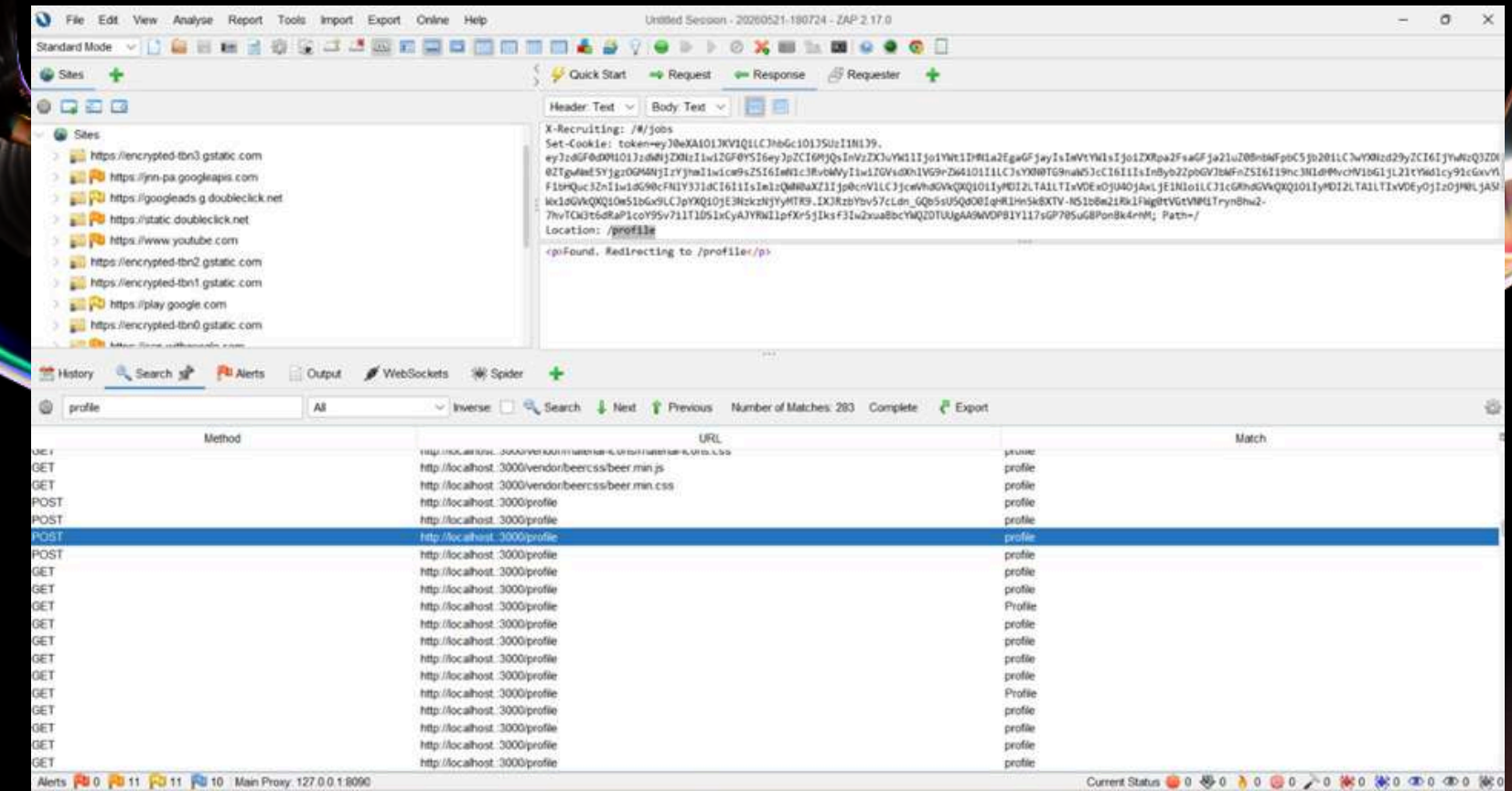
Hasil validasi menunjukkan bahwa cookie sesi tidak memiliki atribut keamanan penting seperti:

- HttpOnly
- Secure
- SameSite

Kondisi tersebut menyebabkan:

- Token JWT dapat diakses melalui JavaScript
- Cookie tetap dikirim melalui koneksi HTTP biasa
- Risiko CSRF menjadi lebih tinggi karena cookie tetap dikirim pada cross-site request

dilakukan secara pasif tanpa eksploitasi aktif, brute force, maupun serangan agresif lainnya sehingga tetap sesuai dengan etika praktikum.



REKOMENDASI

Beberapa rekomendasi perbaikan yang dapat diterapkan:

- Menambahkan token CSRF pada form POST
- Menghapus unsafe-eval dari CSP
- Menambahkan atribut HttpOnly, Secure, dan SameSite
- Menggunakan error handling agar detail server tidak terekspos
- Menambahkan security header pada aplikasi

KESIMPULAN

Pengujian keamanan menggunakan OWASP ZAP berhasil mengidentifikasi beberapa kerentanan pada OWASP Juice Shop. Temuan utama berkaitan dengan keamanan cookie, konfigurasi CSP, dan error disclosure. Praktikum ini memberikan pemahaman mengenai proses analisis keamanan aplikasi web dan pentingnya penerapan konfigurasi keamanan yang baik.

THANK YOU

